

Vulnerability Assessment Report

Simulated Case Study

System Description

The system is a remote database server used by an e-commerce company whose employees work from locations around the world. The server runs a Linux operating system and hosts a MySQL database used by employees to query information and identify potential customers. It communicates over an IPv4 network and uses encrypted SSL/TLS connections. Because the server is remotely accessed and currently exposed to the public internet, its access controls represent an important area of security risk.

Assessment Scope

This vulnerability assessment focuses on the database server's current access controls and the confidentiality, integrity, and availability of the information it stores. The assessment considers risks associated with unauthorized access, data modification, information exposure, and disruption of database availability. Physical security and unrelated organizational systems are outside the scope of this assessment. Risk analysis is guided by NIST SP 800-30 Rev. 1.

Purpose

The database server supports the company's ability to identify potential customers and contributes directly to revenue-generating business activity. Protecting the information it contains is important because unauthorized access, theft, modification, or destruction could create privacy concerns, damage customer trust, and lead to financial or legal consequences. If the server became unavailable, an important part of the company's customer-acquisition process could be interrupted, resulting in lost time, productivity, and business opportunities.

Risk Assessment

The following assessment evaluates three potential threat scenarios using qualitative likelihood and severity scores from 1 to 3. Overall risk is calculated by multiplying likelihood by severity.

Threat Source	Threat Event	Likelihood	Severity	Risk
External hacker	Disrupt database availability	2	2	4
Competitor	Copy prospective-customer information for competitive advantage	2	1	2
Competitor	Alter prospective-customer information to disrupt operations and gain competitive advantage	2	2	4

Assessment Approach

Likelihood was scored based on the database's public exposure while avoiding assumptions about security controls that were not described in the scenario. Severity was based on the degree to which each event could disrupt operations, waste time or resources, reduce business opportunities, or damage the usefulness of the data. The highest scores were not assigned automatically because the available information does not establish that attackers can easily bypass authentication or that every event would cause severe organizational harm.

Remediation Strategy

The database should be removed from unnecessary public exposure and restricted using firewall rules, IP allow-listing, or VPN-based access where appropriate. Role-based access control, least privilege, and multi-factor authentication should limit both who can access the system and what actions each user can perform. Access and change activity should be logged and monitored so suspicious behavior can be detected and investigated, with periodic internal reviews used to confirm that controls remain effective. Data in transit should be protected with TLS and securely managed certificates and keys.